IT Resources Patching Policy

Effective Date:
October 1, 2026

Category:
Security

Scheduled Review:
October 2027

1. Authority

Executive Order 2016-06, Enterprise Information Technology Governance

2. Document Control

This document replaces, in its entirety, the *IT Resources Patching Policy*, dated January 6, 2025.

3. Purpose

This Information Technology Policy (ITP) sets forth the requirements for the timely application of security patches.

4. Scope

This policy applies to all offices, departments, boards, commissions, and councils under the Governor's jurisdiction and any other entity connecting to the Commonwealth Network (hereinafter referred to as "agencies").

5. Policy

For definitions of terms found within this document, refer to the *IT Policy Glossary*.

5.1 General Requirements

Agencies shall ensure the most recent cumulative updates and security patches are applied to Commonwealth IT resources, including, but not limited to any resource with an Internet Protocol (IP) address and/or a Media Access Control (MAC) address, in accordance with this policy and the and the *IT Resources Patching Standard*.

The Enterprise Information Security Office (EISO) shall provide security patch information/updates, vendor severity ratings and in some instances Commonwealth severity ratings (when they vary from vendor) on the IT Central Security Services Page (*Authorized access only*).

EISO Notifications shall be sent to the Agency Information Security Officer (ISO). Agencies shall contact OA, EISO Notifications (RA-OAEISONOTIFICATIO@pa.gov) if there is a need for additional users to be added to the notification list.

In addition to the information/updates provided by EISO, Agencies shall ensure that technology owners are monitoring vendor resources (e.g., email, website, etc.) for associated vulnerability announcements and patch updates for the Commonwealth IT resources they support.

In the event the EISO assigns a higher severity rating than the manufacturer, the severity rating assigned by the EISO shall be used.

To ensure agency patching is conducted in accordance with this policy, the Agency ISO is authorized to conduct compliance audits and provide guidance on associated risks and vulnerabilities.

The EISO shall select, maintain, and manage enterprise patch and vulnerability assessment tools used to identify missing patches and security updates. Agencies shall engage the EISO prior to selecting or deploying additional tools for assessing patch needs on Commonwealth assets.

5.2 Security Patching Requirements

The severity levels, along with maximum deployment timelines for each severity level are defined in the *IT Resources Patching Standard*. Agencies shall refer to that document to determine and implement appropriate patching schedules.

To ensure consistent patching of Commonwealth IT Resources, agencies shall:

- Establish and maintain a standardized internal patch management policy aligned with this policy and the *IT Resources Patching Standard.*
    - Patching timelines defined by agencies shall be no less stringent than those established by this policy and the *IT Resources Patching Standard*.
    - The *Agency IT Resources Patching Schedule Procedure may be used as* an optional template and may be modified as necessary to meet agency-specific operational requirements.
- Document a security patching schedule that defines patching frequency for each supported platform. (e.g., AIX – Bi-annually, Mainframe – Quarterly).
    - Routine schedules do not eliminate the requirement to deploy higher-severity patches on an expedited basis.
    - For third-party managed platforms, security patching schedules and responsibilities shall be documented in applicable contracts
- Plan and implement monthly rollup patching activities, including communication of announced security patches to impacted or affected entities.
    - Agencies shall review patching plans on a monthly basis to determine whether deviations from established patch schedules are required.
- Monitor patch advisories and recommendations issued by software manufacturers, third-party entities, and federal partners, and apply patches in accordance with such guidance and industry best practices.
- Prioritize, test, validate, deploy, and track security patches based on risk.

- Patch deployment shall be prioritized using asset criticality, data classification, and exposure. Systems that support or store Class C data, systems designated as mission-critical, and systems that are internet-facing or otherwise highly exposed shall be addressed first.

- Agencies shall maintain visibility into identified vulnerabilities, track patching status and associated residual risk, and ensure remediation or an approved exception is in place in accordance with assigned severity levels and defined patching timeline

- Security patches shall be tested prior to deployment in accordance with the requirements and guidance defined in the *IT Resources Patching Standard*.

5.3 Network Devices and Security Appliances

Agencies shall ensure network devices and security appliances are upgraded and patched to remediate known vulnerabilities. Patching and upgrade activities for these devices shall be performed in accordance with this policy and the timelines and guidance defined in the *IT Resources Patching Standard*.

5.4 Internet of Things (IoT) and Supervisory Control and Data Acquisition (SCADA)

Agencies shall ensure IoT and SCADA devices are upgraded and patched to remediate known vulnerabilities. Patching and upgrade activities for these devices shall be conducted in accordance with this policy and the timelines and guidance defined in the *IT Resources Patching Standard*.

5.5 New Firmware, Middleware, Software, and Operating Systems

Agencies shall coordinate with the EISO at RA-OAEISOVulnMgmt@pa.gov regarding the upgrade or deployment of new firmware, middleware, software, operating systems, or supporting services that enable an application to deliver functionality or services.

For desktop and server operating systems, agencies shall comply with the requirements defined in the Desktop and Laptop Operating System Standard and the Server Operating System Standard, as applicable.

OA/IT may direct the installation or deployment of new or replacement software, if deemed critical by the EISO.

5.6 Managing Mobile Devices

Authorized users who are issued Commonwealth Mobile Devices are responsible for monitoring for and ensuring routine security updates are installed within the timeframe detailed in the *IT Resources Patching Schedule Procedure*.

OA shall provide notification to end users of the availability of critical security updates for Mobile Devices which require immediate installation.

Agencies in coordination with the enterprise are responsible for ensuring users are installing updates in accordance with established timelines to provide for the adequate protection of Commonwealth data.

The installation of updates on Mobile Devices requires a wi-fi connection. As per policy, this shall be a non-public connection, users should refer to the *Mobile Device Policy* for policy guidance on mobile devices in regard to the restriction on connections to public wi-fi.

5.7 Zero-Day/Actively Exploited Critical Vulnerabilities

Zero-day/actively exploited critical vulnerabilities shall be dealt with on an ad-hoc basis as determined by OA, agency, and external supplier ISOs. This patching shall be completed on an expedited schedule upon release of vendor supplied patch or workaround, while maintaining the general guidelines for patching (testing prior to production, where possible). Refer to the *IT Resources Patching Standard* for further guidance regarding emergency patching and mitigation measures.

5.8 Active Outbreaks

For systems or networks in which an active outbreak has been found, and a quarantine is required, the agency may be disconnected from the Commonwealth network until the outbreak is resolved. This decision to disconnect an agency from the Commonwealth Network is at the discretion of the Commonwealth Chief Information Officer (CIO), in coordination with the Commonwealth Chief Information Security Officer (CISO), Commonwealth Chief Technology Officer (CTO), or designee and the impacted agency's CIO, ISO, CTO, or designee. Notification of a probable or imminent quarantine or disconnection from the Commonwealth network shall be made to the affected agency CIO, ISO, CTO, or designee as soon as practical and before the actual disconnection occurs.

6. Contact

Questions or comments may be directed via email to OA, IT Policy

7. Exception from Policy

In the event an agency chooses to seek an exception from this policy, a request for a policy exception shall be submitted via the IT policy exception process. Refer to *IT Policy Governance Policy* for guidance.

8. Revision History

This chart contains a history of this publication's revisions. Redline documents outline the revisions and are available to Commonwealth users only during the drafting process.

Version	Date	Purpose of Revision
Original	01/06/2025	Base Document
Revision	10/01/2026	Clarified EISO and Agency responsibilities Expanded Security Patching Requirements to emphasize risk-based prioritization Added requirements for agencies to track vulnerabilities, patching status, and residual risk Improved alignment between the policy and the IT Resources Patching Standard